

Password & Access Control Policy

Field	Details
Version	1.0
Author	Durva Amin
Date	23 August 2026
Status	Draft

Purpose

To establish requirements for secure password management and access control within the organisation, helping protect systems and information from unauthorised access.

Scope

This policy applies to organisational users, accounts, systems, applications, and information requiring access control and password protection.

Table of Contents

Purpose	1
Scope.....	1
Roles & Responsibilities	3
Password Requirements.....	4
MFA Requirements.....	5
Least Privilege	6
Need to Know.....	7
Access Management	8
Privileged Access.....	9
Access Review	10
Exceptions	11
Monitoring	12
Access Control Matrix	13
Version History	14

Roles & Responsibilities

Role	Responsibility
Users	Follow password and access control requirements.
Managers	Approve access requests based on business need.
IT Team	Implement and maintain access controls.
Information Security Team	Monitor compliance with this policy.

Password Requirements

Passwords must be created and managed according to organisational security requirements. Users must protect their passwords and must not share them with other individuals.

- Passwords must be unique for organisational accounts.
- Passwords must meet the organisation's defined length and complexity requirements.
- Users must not share passwords with others.
- Passwords must not be written or stored in insecure locations.
- Default passwords must be changed before an account or system is used.
- Compromised or suspected compromised passwords must be changed immediately.
- Users should use an approved password manager where permitted by the organisation.

MFA Requirements

Multi-Factor Authentication (MFA) should be used to provide an additional layer of protection for organisational accounts and systems. Where MFA is required, users must complete the approved authentication factors before access is granted.

- MFA must be enabled for accounts and systems where required by the organisation.
- Users must use approved authentication methods.
- Authentication factors must not be shared with other individuals.
- Users must report suspected compromise or unauthorised MFA activity.
- MFA settings should be reviewed when required to ensure they remain appropriately configured.
- MFA must be required for privileged or high-risk access where applicable.

Least Privilege

Access to organisational systems and information must be limited to the minimum level of privileges required for users to perform their assigned responsibilities.

- Users should receive only the access required for their job responsibilities.
- Unnecessary or excessive privileges must be avoided.
- Access permissions should be reviewed periodically.
- Privileged access should be limited to authorised personnel.
- Access should be removed or adjusted when job responsibilities change.
- Access that is no longer required must be revoked promptly.

Need to Know

Access to sensitive or confidential information must be provided only when it is necessary for a user's authorised job responsibilities.

- Access to sensitive information must be based on a legitimate business need.
- Users must not access information that is not required for their responsibilities.
- Access to confidential information should be limited to authorised personnel.
- Need-to-know access should be reviewed periodically.
- Access must be removed when the business need no longer exists.
- Users must not share restricted information with unauthorised individuals.

Access Management

Access to organisational systems and information must be requested, approved, provisioned, reviewed, modified, and revoked according to defined access management procedures.

- Access requests must be submitted through an approved process.
- Access must be approved by the appropriate manager or authorised person.
- Access should be granted according to job responsibilities and business requirements.
- User access must be modified when responsibilities change.
- Access must be revoked when it is no longer required, including during employee offboarding.
- Access activities should be documented for accountability and review.
- Access to sensitive systems should receive appropriate additional controls.

Privileged Access

Privileged access must be restricted to authorised personnel who require elevated permissions to perform approved administrative or security-related responsibilities.

- Privileged access must be granted only when required for authorised responsibilities.
- Privileged accounts should be separate from standard user accounts where appropriate.
- Privileged access must be approved by an authorised person.
- Privileged accounts must use strong authentication, including MFA where required.
- Privileged activities should be logged and monitored.
- Privileged access should be reviewed periodically.
- Privileged access must be revoked when it is no longer required.

Access Review

User access must be reviewed periodically to confirm that permissions remain appropriate for current job responsibilities and business requirements.

- User access should be reviewed at defined intervals.
- Access reviews should identify unnecessary, excessive, or inappropriate permissions.
- Managers or designated access owners should confirm that access remains required.
- Changes identified during reviews should be documented and addressed promptly.
- Access that is no longer required must be revoked.
- Evidence of completed access reviews should be retained according to organisational requirements.

Exceptions

Exceptions to the requirements of this policy must be formally documented, justified, reviewed, and approved by an authorised person before they are implemented.

- Exceptions must have a valid business or technical justification.
- The reason for the exception must be documented.
- The associated security risk should be assessed.
- Exceptions must have an identified owner.
- Exceptions should have an approval and review process.
- Compensating controls should be considered where appropriate.
- Exceptions should have a defined review or expiration date.
- Approved exceptions must be documented and retained.

Monitoring

Access and authentication activities should be monitored to identify unauthorised access, suspicious activity, and potential violations of this policy.

- Authentication and access activities should be monitored where appropriate.
- Privileged activities should be logged and monitored.
- Suspicious or unauthorised access attempts should be investigated.
- Security logs should be protected from unauthorised modification.
- Monitoring activities should support incident detection and investigation.
- Identified security issues should be reported and addressed according to organisational procedures.

Access Control Matrix

The following access control matrix defines the permitted level of access for different organizational roles based on their job responsibilities and business requirements.

Role	Employee Records	Financial Records	IT Systems	Access Level
HR Staff	Read/Write	No Access	No Access	Standard
Finance Staff	No Access	Read/Write	No Access	Standard
IT Administrator	No Access	No Access	Admin	Privileged
Manager	Read	Read	No Access	Standard

Version History

Version	Date	Author	Changes
1.0	23 August 2026	Durva Amin	Initial Release

Document Status: Draft